Security Posture Review — przed i po hardeningu

Laboratorium Azure: celowe błędy konfiguracji, wykrywanie (Defender for Cloud, Azure Policy, przegląd ręczny), naprawa i prewencja. Listopad 2026.

1. Zakres i metoda

Cel. Celem audytu było zmierzenie, jak celowe błędy konfiguracji w małym środowisku laboratoryjnym wpłyną na Secure Score oraz Microsoft cloud security benchmark (MCSB) w Defender for Cloud, oraz ile z nich wykryją Defender for Cloud i Azure Policy.

Środowisko. Subskrypcja pay-as-you-go, jedna grupa zasobów w regionie West Europe. Zasoby: konto Storage, Key Vault, maszyna wirtualna Linux (D2 v3) z NSG, siecią wirtualną i publicznym adresem IP, obszar roboczy Log Analytics oraz testowe konto użytkownika w Entra ID.

Okres. Sabotaż 2.11.2026, audyt i naprawa 3.11, pomiary po naprawie 4.11 i 7.11.

Narzędzia. Defender for Cloud w wersji darmowej (Foundational CSPM), Azure Policy z inicjatywą ASC Default (MCSB), przegląd ręczny (IAM, reguły NSG, logi SSH przez Run command).

Metoda. Środowisko testowe nie zawierało zasobów, więc żeby pokazać skuteczność narzędzi, najpierw celowo wprowadziłem błędy konfiguracji. Znając dokładną listę błędów, mogłem zmierzyć, ile z nich wykryło każde narzędzie. Pracę trzeba było rozłożyć w czasie, ponieważ ocena w Defender for Cloud zajmuje do ok. 24 h, a w Azure Policy kilkanaście–kilkadziesiąt minut. Dzięki temu zmierzyłem też, jak celowe błędy wpływają na Secure Score i MCSB.

Ograniczenia. Na wyniki wpływają: darmowa wersja Defendera, opóźnienie ocen Defendera oraz pomiar „po" wykonany już bez VM (usuniętej ze względu na koszty), więc wzrost wyniku częściowo wynika z usunięcia maszyny. Lab był mały, więc pojedyncze błędy znacząco wpływały na wynik; w dużej firmie ten sam błąd zmienia wynik o niewielki punkt procentowy. Dla znaleziska 8 nie zachowano zrzutu stanu „przed". Zrzuty zostały celowo zanonimizowane (m.in. zamazany mój publiczny adres IP, identyfikatory subskrypcji i dane osobowe); puste pola w tych miejscach wynikają z anonimizacji, a nie z konfiguracji.

2. Wyniki w liczbach

Wskaźnik	Przed sabotażem	Po sabotażu	Po naprawie (7.11, VM usunięta)
Secure Score	100% (D01)	9% (D02)	69% (D24)
MCSB — zaliczone kontrole	57/63 (D01)	46/63 (D02)	55/63 (D24)
Rekomendacje Unhealthy — razem	—	15: 3 High, 9 Medium, 3 Low (D03)	8 (D25)
Rekomendacje Unhealthy — Storage + Key Vault	—	9 (D03)	3 (D25)

Pokrycie 8 wprowadzonych błędów: Defender 6/8, Azure Policy 7/8, wyłącznie przegląd ręczny 1/8 (rola Owner).

Po naprawie: 3 rekomendacje Storage i Key Vault, które zostały, nie wynikały z sabotażu: dwie dotyczą private link (wymaga Private Endpoint, czyli zmiany architektury), jedna reguł VNet (świadomie pozostawiony dostęp z mojego adresu IP). Pozostałe 5 dotyczy subskrypcji (płatne plany Defender, liczba ownerów). Pomiar pośredni z 4.11 (Secure Score 42%, D15) pokazuje opóźnienie Defendera: wynik rósł przez kolejne dni bez żadnych zmian w konfiguracji.

3. Ustalenia

#	Znalezisko	Zasób	Severity	Źródło	Ryzyko („atakujący mógł…”)	Naprawa	Prewencja	Dowód
1	Anonimowy dostęp do kontenera	Storage	Medium	Defender + Policy	Każdy w internecie mógł pobrać zawartość kontenera bez żadnego uwierzytelnienia	Storage account → **Settings → Configuration** → *Allow Blob anonymous access* = **Disabled** → Save	Azure Policy, Deny (blokuje utworzenie): Storage account public access should be disallowed Azure Policy, Modify (Azure sam wyłącza): Configure your Storage account public access to be disallowed	D3, D5 → D10
2	Brak wymuszonego HTTPS (secure transfer)	Storage	High	Defender + Policy	Storage akceptował połączenia HTTP. Ktoś na drodze sieciowej np. publiczne Wi-Fi mógł podejrzeć lub zmienić przesyłane dane i przechwycić tokeny SAS	Storage account → **Settings → Configuration** → *Secure transfer required* = **Enabled** → Save	Azure Policy, Deny (blokuje utworzenie): Secure transfer to storage accounts should be enabled Azure Policy, Modify (Azure sam włącza): Configure secure transfer of data on a storage account	D3 → D14
3	Dostęp sieciowy ze wszystkich sieci	Storage	Medium	Defender + Policy	Storage był osiągalny z całego internetu. Każdy, kto zdobył klucz lub token, albo trafił na publiczny kontener, mógł dostać się do danych z dowolnego miejsca.	Storage account → **Security + networking → Networking** → *Manage* → **Enable** → *Enabled from selected networks*. Potem w *Virtual networks, IP addresses, and exceptions* → *View* → dodany mój publiczny adres IP → Save	Azure Policy, Deny (blokuje utworzenie): Storage accounts should restrict network access Szablony IaC z ograniczonym dostępem sieciowym	D3 → D21, D14
4	Brak logów (Diagnostic Settings)	Key Vault	Low	Defender + Policy	Odczyty sekretów nie były rejestrowane. Nieautoryzowane użycie sekretu nie zostałoby wykryte, a po incydencie nie dałoby się ustalić, kto i kiedy go odczytał.	Key Vault → **Monitoring → Diagnostic settings** → *+ Add diagnostic setting* → zaznacz logi (audit) → *Send to Log Analytics workspace* → Save	Azure Policy, DeployIfNotExists (Azure sam dodaje logi): Deploy - Configure diagnostic settings for Azure Key Vault to Log Analytics workspace	D3, D17, D18 → D20
5	Brak purge protection	Key Vault	Medium	Defender + Policy	Użytkownik z uprawnieniami (insider lub przejęte konto) mógł usunąć Key Vault i od razu go wyczyścić. Sekrety i klucze przepadłyby bezpowrotnie.	Key Vault → **Settings → Properties** → *Enable purge protection* → Save	Azure Policy, Deny (blokuje utworzenie): Key vaults should have deletion protection enabled	D3, D17 → D19

#	Znalezisko	Zasób	Severity	Źródło	Ryzyko („atakujący mógł…”)	Naprawa	Prewencja	Dowód
6	Key Vault dostępny ze wszystkich sieci	Key Vault	Medium	Defender + Policy	Jeżeli ktoś przejmie dane do logowania konta, które ma dostęp lub token logowania takiego konta a nie ma ograniczenia co do sieci z których można się dostać to może korzystać z Vault z dowolnego miejsca w internecie.	Key Vault → **Settings → Networking** → *Firewalls and virtual networks* → *Allow public access from specific virtual networks and IP addresses* → dodany mój publiczny adres IP → Apply	Azure Policy, Deny (blokuje utworzenie): Azure Key Vault should have firewall enabled or public network access disabled Azure Policy, Modify (Azure sam włącza firewall): Configure key vaults to enable firewall	D3, D17 → D19
7	SSH (22) otwarty na cały internet	VM	High (ocena własna)	tylko Policy	SSH daje zdalny dostęp do powłoki maszyny. Port 22 był otwarty na cały internet, więc po udanym zalogowaniu się atakujący mógłby niepostrzeżenie usuwać lub zmieniać dane albo wgrać malware. W ok. 4 h odnotowano 19 nieudanych prób logowania z 14 adresów IP.	VM → **Networking → Network settings** → reguła **SSH** → *Source* = **IP Addresses** → *Source IP addresses/CIDR ranges* = mój publiczny adres IP → Save	Napisanie własnej reguły Azure Policy z Deny albo zamknięcie portu i łączenie się inaczej (JIT VM access)	D16, D4, D6–D8 → D11
8	Owner z prawem nadawania wszystkich ról dla dewelopera	RG (IAM)	High (ocena własna)	tylko ręcznie	Deweloper lub ktoś, kto przejmie jego konto miałby pełną kontrolę nad RG. Mógłby usuwać zasoby, nadać sobie dostęp do sekretów Key Vault bądź przypisać Ownera innemu kontu, tworząc trwały backdoor.	Resource group → **Access control (IAM) → Role assignments** → testdev (Owner) → **Delete**. Potem + *Add* → *Add role assignment* → **Reader** → *Members* → testdev → *Review + assign*	Least privilege oraz przegląd uprawnień Alert na Activity Log (Create role assignment) — detekcja	notatki własne → D12

Severity 1–6: Defender for Cloud. Severity 7–8: ocena własna (prawdopodobieństwo × skutek). Dla znaleziska 8 zrzut stanu „przed” (rola Owner z opcją „all roles”) nie został zachowany.

4. Wnioski

Czego Defender nie wykrył i dlaczego?

Defender wykrył 6 z 8 błędów. Nie wykrył SSH otwartego na internet oraz roli Owner dla konta dewelopera. Otwarty SSH wykryła wyłącznie Policy (D16), mimo że reguła należy do tej samej inicjatywy ASC Default — Defender nie pokazuje każdego wyniku Policy jako rekomendacji. Defender sprawdza jedynie liczbę ownerów subskrypcji, a nie to, czy konkretna osoba powinna być ownerem. Jest to decyzja na poziomie organizacji i każde nadmiarowe nadanie roli Owner powinno być weryfikowane ręcznie w IAM. Uzupełniająco można ustawić alert na zdarzenie „Create role assignment" w Activity Log (detekcja). Brak rekomendacji to nie brak problemu: trzeba porównać oba źródła, Defender for Cloud i Azure Policy, a także wykonać przegląd ręczny. Narzędzie widzi konfigurację, a nie kontekst biznesowy organizacji.

Co Policy zablokowałaby od początku, gdyby była przypisana przed sabotażem?

ASC Default była przypisana przed sabotażem, ale reguły mają w niej efekt Audit, dlatego widzimy jedynie, co jest Non-compliant. Microsoft nie ustawia reguł domyślnie jako Deny, ponieważ każde środowisko jest inne i to, czy coś ma być blokowane, zależy od indywidualnych potrzeb klienta. Z efektem Deny nie dałoby się utworzyć błędnie skonfigurowanych zasobów w znaleziskach 1, 2, 3, 5 i 6. Dla znaleziska 4 Deny nie istnieje, ale DeployIfNotExists sam dodałby logi — błąd zostałby naprawiony automatycznie, choć nie zablokowany. Dla znaleziska 7 wbudowana reguła tylko audytuje; SSH zablokowałaby dopiero własna reguła z Deny albo zakaz publicznych IP dla VM. W znalezisku 8 Policy nie pomoże, bo uprawnienia trzeba weryfikować ręcznie. Podsumowując: Policy z Deny zablokowałaby 5 z 8 błędów, a z DeployIfNotExists 6 z 8 byłoby zablokowanych lub naprawionych automatycznie. Skuteczność Deny potwierdził test z regułą Allowed locations — utworzenie zasobu w niedozwolonym regionie zostało zablokowane już w formularzu (D13).

Ile prób logowania przyszło na SSH i co to mówi o otwartych portach?

19 nieudanych prób z 14 unikalnych adresów IP w około 4 h (D06, D07). Dwa adresy odpowiadały za najwięcej wpisów, po 8 każdy (D08). VM nie była używana przez SSH, więc wszystkie próby pochodziły z zewnątrz. Nikt nie szukał właśnie tej maszyny — to automatyczne skanery, które sprawdzają cały internet w poszukiwaniu celów. Ataki odparło logowanie kluczem (kontrola kompensująca), a nie zamknięty port. Otwarty port 22 jest atakowany w ciągu kilku godzin, a logowanie kluczem nie wystarcza: klucz może wyciec, a podatność w samym SSH pozwala ominąć logowanie. Port 22 nie powinien być wystawiony do internetu; dostęp powinien odbywać się przez JIT VM access.

5. Rekomendacje na przyszłość

Gdybym odpowiadał za bezpieczeństwo prawdziwej firmy w Azure, na podstawie tego labu wdrożyłbym:

1. **Reguły Azure Policy z efektem Deny** przypisane na poziomie subskrypcji lub management group — dzięki dziedziczeniu chronią wszystkie zasoby niższego rzędu, także te utworzone w przyszłości. Wdrażane etapami: najpierw Audit, potem Deny.
2. **Szablony tworzenia zasobów** — ujednolicone, żeby uniknąć błędu ludzkiego.
3. **RBAC:** zasada least privilege i regularny przegląd uprawnień, a uzupełniająco alert na zdarzenie „Create role assignment" w Activity Log (detekcja), żeby wychwycić nadawanie ról administracyjnych.
4. **Ograniczanie dostępu sieciowego:** domyślne blokowanie i dostęp tylko z określonych sieci lub adresów.
5. **Porty zarządzania (SSH/RDP):** wystawianie ich do internetu to proszenie się o kłopoty. Port powinien być domyślnie zamknięty i otwierany tylko na żądanie, dla konkretnego adresu IP i na ograniczony czas (JIT VM access w Defender for Servers Plan 2).
6. **Key Vault:** włączone logi diagnostyczne i purge protection. W firmie o krytycznym znaczeniu (np. dostawcy dla szpitali) utrata kluczy mogłaby zatrzymać produkcję, a skutki wykraczałyby poza straty finansowe.

Załącznik — lista dowodów

#	Co pokazuje
D01	Secure Score 100%, MCSB 57/63 — przed sabotażem
D02	Secure Score 9%, MCSB 46/63 — po sabotażu
D03	Eksport rekomendacji Defendera po sabotażu (nie publikowany — zawiera identyfikatory)
D04	Reguła NSG: SSH (22), źródło Any
D05	Plik w kontenerze dostępny bez logowania
D06	Run command: 19 nieudanych prób logowania SSH
D07	Run command: 14 unikalnych adresów IP
D08	Run command: adresy IP z liczbą prób
D10	Ten sam plik po naprawie: PublicAccessNotPermitted
D11	Reguła NSG po naprawie: SSH tylko z mojego adresu IP
D12	IAM grupy zasobów po naprawie: konto testowe z rolą Reader
D13	Allowed locations (Deny): region spoza listy zablokowany w formularzu
D14	Eksport rekomendacji 4.11 (nie publikowany)
D15	Secure Score 42% — pomiar pośredni 4.11
D16	Policy: Management ports should be closed — Non-compliant
D17	Policy: Key Vault — 4 niezgodne reguły przed naprawą
D18	Key Vault: brak Diagnostic Settings
D19	Policy: Key Vault — 2 niezgodne reguły po naprawie
D20	Policy: Resource logs in Key Vault — Compliant po naprawie
D21	Policy: Storage — 2 pozostałe reguły po naprawie
D24	Secure Score 69%, MCSB 55/63 — 7.11
D25	Eksport rekomendacji 7.11 (nie publikowany)